Kerbo-S Change Document, Sprint 2

Nov 7, 2026 · @Jaynne

Team: Chance Edwards, Ben Grider, David Pantoja, Jessica Yescas

Sprint 2 ran for one week (Nov 1 to Nov 7) instead of the four weeks first planned, so the scope was cut and twelve cards moved to Sprint 3. This document records every change made during Sprint 2: what changed, why, and the impact. It continues the numbering of the Sprint 1 Change Document, so RC-11, DC-08, IC-03 and PC-06 follow on from Sprint 1. References are to Requirements v2.1, Design v2.1, the Sprint 2 Test Plan, the Sprint 2 Plan, Trello card IDs (S2-xx) and GitHub pull requests (#n).

1. Summary

Area	Changes	Headline
Requirements	4 (RC-11 to RC-14)	Scope cut to one week; KC-05 to Sprint 3; KC-06 limited to admin principals; test cases added and moved
Design	9 (DC-08 to DC-16)	New data models, a parsers package, config object IDs, KC-06 justification file, aged fixture copies, two fixes found on real lab data, SQLite as built, clear error exit codes
Implementation	5 (IC-03 to IC-07)	Public repository; lab moved to Proxmox; all Sprint 2 code delivered in pull requests #6 to #18 (68 tests pass); remaining cards redistributed so all of Sprint 2 is completed; demo on hold
Process	5 adopted from Sprint 1, 4 new (PC-06 to PC-09)	Pull requests, per-member guides, a daily participation record, a credentials rule and a code freeze

2. Requirement Changes

ID	What changed	Why	Impact	Ref
RC-11	Sprint 2 was cut from four weeks to one. AI analysis, reports and PDF export, the log rules (KC-05, KC-10, KC-11), evidence hashing and the evaluation script moved to Sprint 3, twelve cards in all.	Sprint 1 recovery used the start of the sprint, and Sprint 2 is due Nov 7.	Sprint 2 covers the lab, parsers, rules, scoring, storage and a first GUI table. The AI and reporting requirements stay Outstanding until Sprint 3.	Sprint 2 Plan
RC-12	KC-05 (inactive service principal) moved to Sprint 3.	It needs service-ticket (TGS) requests from the KDC log, and the log parser (S2-07) is in Sprint 3. The `getprinc` last-authentication field does not change when a service ticket is used, so there is no Sprint 2 data for it.	TC-KC-05 stays Not Yet Tested.	Req 6.1, S2-09
RC-13	KC-06 checks only admin principals (the `/admin` instance) against a justification file in Sprint 2. Reading `kadm5.acl` for other privileged entries moved to Sprint 3.	The ACL parser is part of S2-07 (Sprint 3).	Privileged principals without an `/admin` instance are not yet checked.	RC-02, S2-09

ID	What changed	Why	Impact	Ref
RC-14	Test cases added: TC-KC-15 (planted and aged fixtures match their manifest) and TC-UI-06 (missing or malformed snapshot handled). TC-UI-04 moved to Sprint 3.	TC-UI-04 as written needs a live audit against the KDC; Sprint 2 audits read saved lab output.	The test plan gains two cases; one moves to Sprint 3.	S2-16, S2-22

3. Design Changes

ID	What changed	Why	Impact	Ref
DC-08	New data models: `Policy` (name, minimum length, maximum and minimum life, history, lockout failures) and `ConfigSetting`. `Snapshot` gained `policies`, `config` and `errors` lists.	KC-03 needs password policies; KC-07 to KC-09 need configuration settings; parse errors must be kept rather than crash the audit.	One shared shape for every parser and rule.	PR #6
DC-09	Parsers live in a `kerbo_s/parsers/` package. `kadmin.py` reads `getprinc` and `getpol` output and classifies principals as user, admin, service or internal. `kerberos_conf.py` reads `krb5.conf` and `kdc.conf`, including nested realm blocks and MIT duration formats. A malformed line is recorded as an error and parsing continues. `load_fixture_dir` builds a Snapshot from a folder that holds a `collected_at.txt` timestamp.	Separates reading the KDC's text output from the rules (design principle D-02), and lets tests run on saved files without the VM.	Rules never touch raw text. The loader was extended to read `krb5.conf` and `kdc.conf` (PR #15), so KC-07 to KC-09 run end to end on lab data.	PR #7, PR #9, PR #15
DC-10	Configuration findings are identified as file/section/key, for example `kdc.conf/realms/KERBO.LAB/max_life`.	A stable ID lets test manifests match findings exactly (rule ID + object ID).	The planted and aged manifests use the same IDs.	PR #6, PR #9
DC-11	KC-06 reads the path of its justification file from `config/rules.yaml`. A missing file means no admin is approved, so every admin is reported. A site's real file is not committed; tests use `tests/fixtures/real/admin_justifications.yaml`.	Justifications are site data, not code. Failing safe means a missing file can't hide an unjustified admin.	Approved admins can be changed without code changes.	PR #9, PR #10
DC-12	Aged fixture copies for TV-01, TV-02 and TV-04: captured lab output with older date fields, written down in an expected-findings manifest before the audit.	A new lab realm can't produce 90-day-old passwords or inactive accounts within a one-week sprint.	Built after the redistribution (IC-06): the aged folder changes six date lines of the planted capture, each listed in its README. TC-KC-15 passes with 11 of 11 expected findings.	S2-03, PR #14

ID	What changed	Why	Impact	Ref
DC-13	The configuration parser skips `include`, `includedir` and `module` lines.	The real lab `krb5.conf` contains `includedir /etc/krb5.conf.d/`, which was being recorded as a parse error (test plan defect DF-02). Found on Ben's captured data Nov 6.	The clean realm loads with no errors. Settings inside included files are not read yet.	PR #13
DC-14	KC-07 checks every colon-separated part of a key label.	The lab KDC lists RC4 keys as `DEPRECATED:arcfour-hmac`, so the planted RC4 key was missed (defect DF-01). Found on Ben's captured data Nov 6.	The planted weak key is reported; a test covers the new label.	PR #13
DC-15	KC-04 measures a never-authenticated user from the last password change date instead of the creation date.	`getprinc` prints no creation date; the first password is set when the account is created.	Requirements v2.1 C-24. A password reset on a never-used account restarts the count.	PR #13
DC-16	SQLite built with five of the seven designed tables (`audits`, `artifacts`, `findings`, `reviews`, `collection_errors`) and the two immutability triggers. The CLI saves every audit (`--db`) and exits with code 3 if the save fails. A missing or malformed snapshot gives one clear message and exit code 2 in the CLI, a message box in the window.	Build only the tables that have Sprint 2 data; keep error output readable (TC-UI-06).	`ai_outputs` and `reports` are added in Sprint 3. The window does not save audits yet.	PR #13, PR #16

4. Implementation Changes

ID	What changed	Why	Impact
IC-03	The GitHub repository was made public on Nov 1. The five Sprint 1 PDFs were added to `docs/sprint1/` (PR #4, #5), `*.keytab` was added to `.gitignore`, and an unused old branch was deleted (PR #8).	The instructor and any TA can open it without an invitation. A public repository must never hold Kerberos key files.	Anyone can read the code, so no credentials may ever be committed.

ID	What changed	Why	Impact
IC-04	The KDC lab runs on Proxmox on a team member's home server instead of VirtualBox: Ubuntu Server 26.04, realm KERBO.LAB, principals `alice` and `ben/admin`, policy `standard`. TC-ENV-01 passed on Nov 5. The setup is recorded in `docs/lab-setup.md`.	The member's stated reasons: he already runs a home Proxmox server; the guide's VirtualBox and PowerShell steps assume Windows and he uses a Mac; Proxmox snapshots make switching between the clean and planted realms easier; and the KDC sits on the same network as his development VM. The choice was made without a team decision.	Only that member can reach the lab. Mitigation: the captured fixtures are committed to the repository (S2-04, S2-03) so the tests never depend on the server. Fallback: build a VirtualBox VM from the commands in `docs/lab-setup.md`.
IC-05	Delivered and merged by the Nov 5 code freeze: data models (PR #6), principal and policy parsers with the fixture loader (PR #7), the config parser and rules KC-06 to KC-09 (PR #9), and the lab setup note and admin fixture (PR #10).	Sprint 2 plan.	Full test run on the frozen code: **28 passed, 0 failed** (PR #11). The final run after the redistributed cards merged: **68 passed, 0 failed** (`docs/evidence/pytest-sprint2.txt`, PR #18).

ID	What changed	Why	Impact
IC-06	Remaining Sprint 2 cards were redistributed on Fri Nov 6 at about 10:40 PM so Sprint 2 could be completed in full. Jessica took Chance's remaining cards: rules KC-02 to KC-04 (S2-08), snapshot error messages (S2-16) and the findings table with filters (S2-14), plus the two fixes in DC-13 and DC-14, all in PR #13 (merged Fri 11:21 PM, 53 tests). Ben finished the clean fixtures (S2-04, PR #12) and the planted and aged fixtures (S2-03, PR #14), then took David's remaining parts: the loader finish (S2-06, PR #15), SQLite storage (S2-12, PR #16) and the end-to-end test (S2-22, PR #17), and recorded the test evidence (S2-23, PR #18).	Time constraints. The work was not finished by the code freeze, and the team chose to pull together to finish every Sprint 2 card rather than carry a backlog into Sprint 3. The redistribution was not because David or Chance did not want to do it or did not do their part; the team pulled together to fully complete Sprint 2.	The code freeze was extended for these cards to the Saturday submission. All Sprint 2 code cards were in Done by Sat Nov 7, 1:31 AM, with **68 tests passing**. Trello cards keep their original owner and name who did the work, for example " [Owner: Chance; done by Jessica]".
IC-07	The Sprint 2 demonstration is on hold at the instructor's direction.	Two of the four members had not been attending class or the instructor meetings.	The demo script (S2-25) is deferred until the instructor sets a new date.

5. Process Changes

Status of the Sprint 1 proposals (PC-01 to PC-05).

ID	Proposal	Sprint 2 status
PC-01	All work through branches and pull requests with one reviewer	Mostly in effect: eighteen pull requests (#1 to #18). Exceptions, all documentation or evidence files: Ben pushed two evidence commits straight to main on Thu Nov 5 (1:08 and 1:10 PM) and one screenshot on Sat Nov 7 (12:42 AM); Jessica pushed two screenshot renames by accident on Fri Nov 6 (11:30 to 11:38 PM). PR #16 was merged by its author and reviewed afterward.
PC-02	Trello cards carry an ID, an owner and a due date; Done means merged and tested	In effect. Every Sprint 2 card has an owner, a due date and a "Done when" list.
PC-03	Each member owns a vertical slice	In effect as card ownership by slice: lab and collectors, audit engine, GUI and storage.
PC-04	Two short check-ins a week and a weekly demo	Partly. Check-ins happened through Teams and Trello; the weekly demo did not (see IC-07).
PC-05	AI-assisted output is checked against MIT documentation and lab fixtures	In effect. AI-drafted code was run against the full test suite and the real lab fixtures before merging; that is how DC-13 and DC-14 were found.

New in Sprint 2.

ID	What changed	Why	Impact
PC-06	Each member received a step-by-step Sprint 2 guide (Nov 1) listing every task in order with commands and "Done when" checks.	Sprint 1 showed tasks were not started when only the card described them.	Work can be checked step by step.

ID	What changed	Why	Impact
PC-07	The coordinator keeps a dated daily record of each member's commits, pull requests, card moves and comments. A mandatory team meeting with the instructor was held on Nov 5.	Uneven participation needed an objective record.	The team stayed unchanged, with members given another opportunity to participate. The record feeds the reflection report.
PC-08	Credentials go only through Microsoft Teams, never in shared documents, Trello or the repository (Nov 6).	A lab password was posted in a shared document comment on Nov 5.	The password was flagged to be changed and the comment to be removed. Only the comment's author can delete it; it was still present at the last check on Sat Nov 7.
PC-09	Code freeze on Thursday at 6 PM before the Saturday submission.	Tests and documents must describe the code that is actually submitted.	Extended on Fri Nov 6 for the redistributed cards only (IC-06); the final test run used the code merged at Sat Nov 7, 1:31 AM.

6. Areas With No Significant Change

Area	Statement
Core technology	Python, PyQt6, SQLite, YAML configuration, Git/GitHub and MIT Kerberos: unchanged.
Project scope	Read-only desktop auditing tool; AI explains findings but never decides them; no autonomous remediation: unchanged.
Rule set	Eleven rules, KC-01 to KC-11: unchanged in number and purpose. Only their sprint timing changed (RC-11, RC-12).

Area	Statement
Risk formula	Impact 40%, Exploitability 30%, Exposure 20%, Compliance 10%, and the four severity bands: unchanged. All eight Sprint 2 rules score exactly as Requirements Section 6.2, as tested in TC-RSK-01.
Platform	Ubuntu Linux with MIT Kerberos, realm KERBO.LAB: unchanged. Only the hypervisor changed (IC-04).

7. Impact on Sprint 3

- No Sprint 2 code card carries over: every one was completed under IC-06.
- Sprint 3 starts with the work moved there by RC-11: the KDC log and `kadm5.acl` parsers (S2-07) and rules KC-05, KC-10 and KC-11; the live collector; snapshot export and evidence hashing; the AI Gateway and its evaluation; reports and PDF export; the remaining screens; the compound scenario TV-15; and the evaluation script.
- Design follow-ups found in Sprint 2 (Design v2.1, Section 10.2): read included configuration files, save audits from the window, pin package versions, and run the tests automatically on every pull request.
- Open items that could cause further change: team participation after the Nov 5 meeting, lab access limited to one member (IC-04), the new demonstration date (IC-07), and the final KDC log format.